

Sesión 1

Ciber-recuperación

Resiliencia frente a ransomware basada en integridad de datos

Por qué fallan los backups · cómo operan los atacantes · cómo debe responder el equipo de seguridad

Módulo Gestión de Ciber-Recuperación · Código 92-EAN

Jawy Andrés Romero Pinto · Ingeniero de Ciberseguridad

Universidad Ean · Educación Continua

2 horas · 1h teoría + 1h laboratorio

Agenda de la sesión

Entender la amenaza, ubicarla en los marcos y montar el entorno



Foco del seminario

La estrella polar: recuperar con confianza verificando integridad.



Antecedentes

Qué es cada cosa, cómo opera el negocio del ransomware y su economía.



Panorama de la región

Cuánto ha crecido y qué modalidades vienen en aumento (datos reales).



Cómo atacan y cómo defender

Flujos de ataque por capas, casos de uso y el playbook del defensor.



Marcos y casos

MITRE ATT&CK, NIST CSF 2.0, regla 3-2-1-1-0 y casos EPM e IFX.



Laboratorio (2ª hora)

Entorno reproducible + primer copiloto de triage.

La estrella polar del seminario

Una sola pregunta que ancla cada actividad del curso

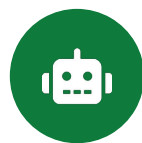


«¿Esto me ayuda a detectar que un backup está corrupto y a identificar la última copia limpia para recuperar con confianza?»



Detección, no solo backup

Tener copias no basta; hay que saber cuál está limpia.



IA como copiloto

El modelo agiliza el triage; el analista valida y decide.



Rigor de investigador

Cada hallazgo se verifica; nada se ejecuta sin evidencia.

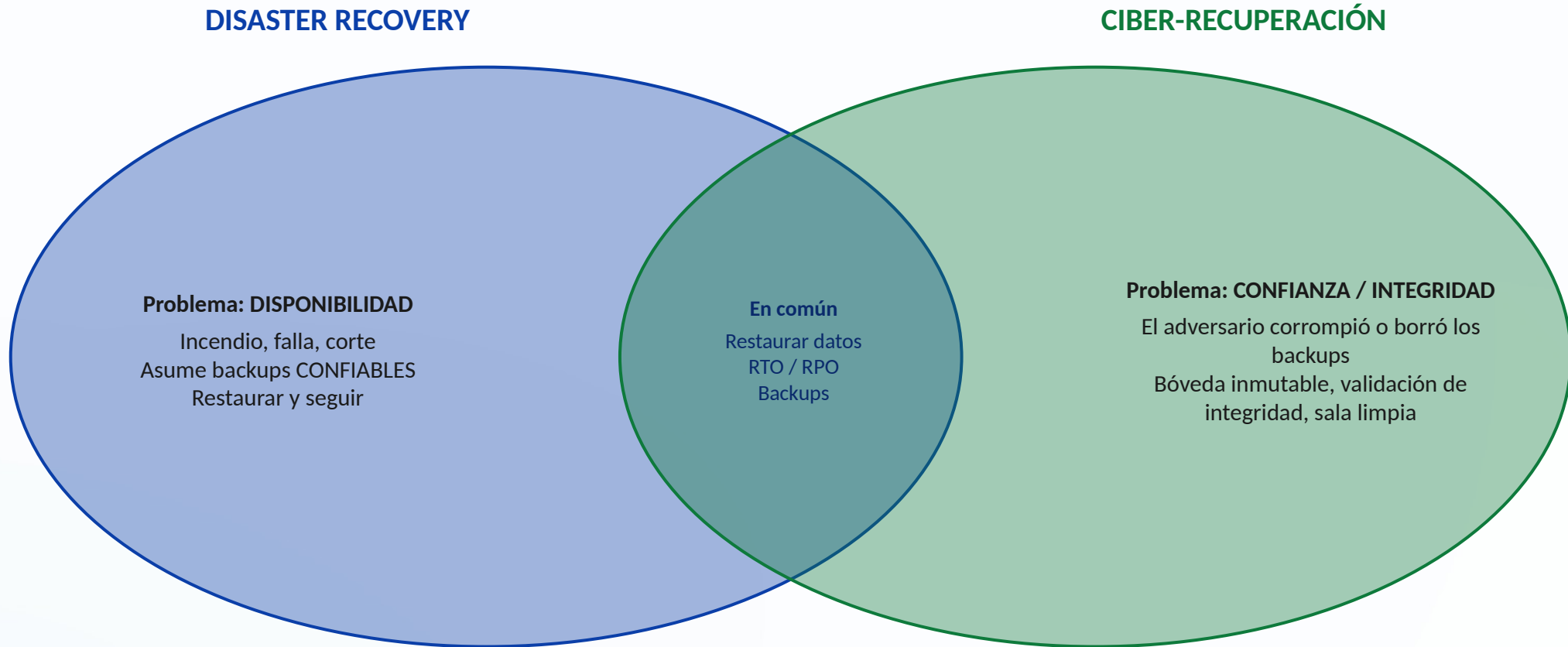


Foco en recuperar

Si una demo no sirve a esta pregunta, sobra.

Esto NO es «recuperación ante desastres»

Disaster Recovery y Ciber-recuperación resuelven problemas distintos



Aclararlo el primer día es tu ancla: todo el curso vive en el círculo verde.

Antecedentes • el vocabulario que usaremos

Cinco términos que hay que tener claros antes de seguir



Ransomware

Malware que cifra datos/sistemas para exigir rescate; hoy además roba datos.



RaaS (Ransomware-as-a-Service)

Modelo de afiliados: un grupo desarrolla, otros ejecutan y reparten el botín.



Doble / triple extorsión

Cifran + amenazan con publicar datos + presionan a clientes o con DDoS.



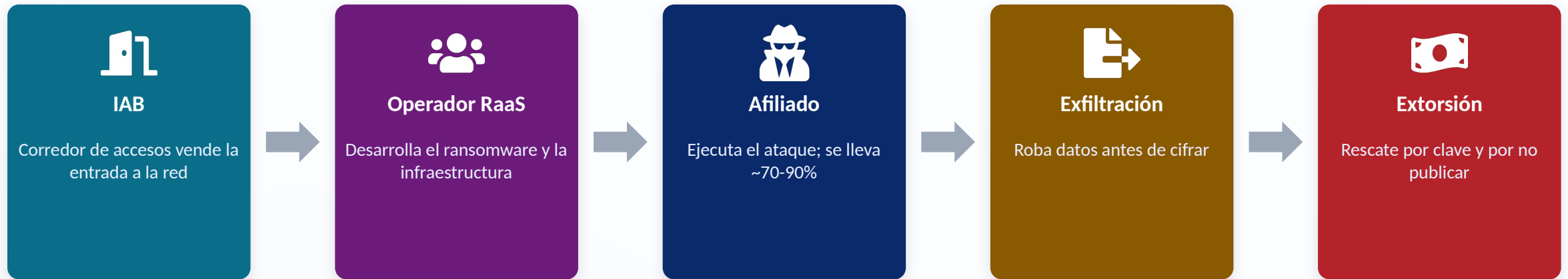
Backup inmutable (WORM)

Copia que no se puede alterar ni borrar durante un periodo: la base para recuperar.

Integridad de datos: garantía de que un dato no fue alterado. Es lo que permite certificar que una copia está limpia antes de restaurar.

Antecedentes • cómo funciona el negocio

El ransomware es una cadena de valor criminal, no un hacker solitario



¿Por qué importa? Como es un negocio con división del trabajo, el volumen crece y los ataques se profesionalizan. La defensa también debe operar como un proceso, no como un héroe.

Ransomware en la región • panorama

ESET Security Report 2025 — +3.000 profesionales en 15+ países de LatAm

27%

de las organizaciones sufrió un ciberataque en el último año

22%

tuvo un incidente de ransomware en los últimos 2 años

95%

considera al ransomware entre las principales amenazas

32%

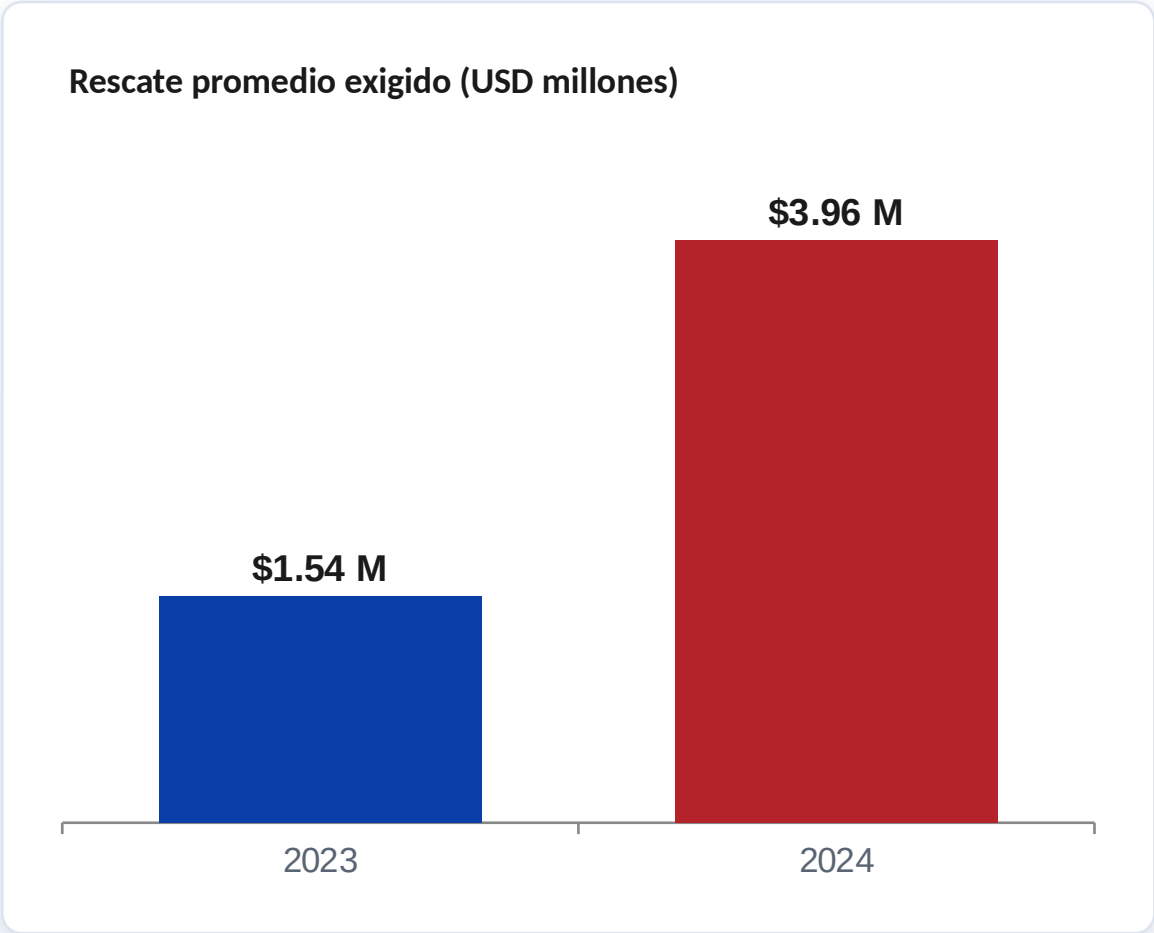
NO tiene herramientas para confirmar si fue atacada

Más atacados: Argentina, Brasil, Chile y México • variantes LockBit, Medusa, RansomHub • blancos: universidades, salud y gobierno.

Ese 32% que no puede confirmar si fue atacada es, literalmente, el problema que este seminario ataca: visibilidad e integridad.

Cuánto ha crecido

La región es la que más rápido crece, y los ataques son más caros



+26% interanual

Ataques por organización/semana en LatAm: el mayor aumento del mundo (Check Point, 2025).



+60% incidentes

Incidentes de ransomware reportados en un mes vs. el año anterior (dic. 2024→2025).



41,6% ya es ransomware

De los incidentes críticos que requieren respuesta de emergencia (vs. 33,3% el año previo - Kaspersky).

Modalidades que vienen creciendo

El ataque evolucionó: ya no es solo cifrar



Doble y triple extorsión

Cifrado + filtración de datos + presión a clientes/DDoS. Hoy es el estándar.



RaaS y afiliados

Plataformas como RansomHub con repartos 90/10; barrera de entrada baja.



Exfil-only

Grupos que ya ni cifran: solo roban y extorsionan con publicar.



Linux, VMware y nube

El foco se mueve a hipervisores y cargas en la nube, no solo Windows.

Implicación para recuperar: si el atacante ya robó los datos, restaurar el backup no borra la extorsión. Por eso la defensa combina integridad, inmutabilidad y detección temprana.

El punto ciego que vamos a atacar

El problema no es solo el ataque: es no poder verlo ni confiar en la recuperación



No sé si me atacaron

32% de las empresas no tiene cómo confirmar un ataque (ESET).



Poca prevención

Menos del 50% implementa tecnología preventiva contra ransomware.



Backups no verificados

Restaurar es una lotería si no sé cuál copia está limpia.



Nuestra respuesta

Integridad + inmutabilidad + copiloto de IA para cerrar la brecha.

Aquí es donde el análisis de integridad y la IA responsable marcan la diferencia — y es exactamente el hilo de todo el módulo.

Al terminar esta sesión, el participante podrá...



Explicar la amenaza

Cómo el ransomware corrompe y borra respaldos y por qué falla la recuperación tradicional.



Ubicar el ataque en ATT&CK

Reconocer T1486 (cifrado) y T1490 (inhibición de recuperación) en un incidente real.



Situar la respuesta en NIST

Relacionar la recuperación con la función RECOVER de CSF 2.0 y la guía SP 800-184.



Levantar el entorno

Dejar Docker y un LLM local/hosted listos como base de las siguientes sesiones.

Cómo operan los atacantes

El ransomware moderno no empieza cifrando: primero entra, roba y sabotea



1. Acceso

Phishing, credenciales o servicio expuesto.



2. Movimiento

Escalada y desplazamiento lateral.



3. Exfiltración

Roban datos antes de cifrar.



4. Sabotaje de respaldos

Borran copias y snapshots (T1490).



5. Cifrado

Cifran datos y sistemas (T1486).



6. Extorsión

Rescate por clave y por no publicar.

Los pasos 4 y 5 son los que rompen la recuperación tradicional. Ahí nos concentramos.

Diagrama de flujo del ataque • por capas

El ataque avanza de arriba hacia abajo; cada capa es una oportunidad de detección



Caso de uso 1 • Sabotaje de respaldos (T1490)

El atacante va por tu red de seguridad antes de cifrar



Cómo lo neutralizamos: una bóveda inmutable (WORM / Object Lock) hace que el paso 3 sea imposible — el atacante no puede borrar lo que no se puede alterar. Más monitoreo de integridad (AIDE/Wazuh) para alertar si alguien lo intenta.

Caso de uso 2 • Doble extorsión (exfil + cifrado)

Aunque restaures, la amenaza de publicar tus datos sigue viva



Cómo lo enfrentamos: detección temprana de la exfiltración (salida masiva de datos) y asumir la fuga en el plan. Recuperar rápido reduce el impacto operativo, pero la lección es que el backup no borra la extorsión: hay que detectar antes de la etapa de cifrado.

Por qué fallan los backups tradicionales

Tener copias no es lo mismo que poder recuperar con confianza



Backups alcanzables

Si están en la misma red y con las mismas credenciales, también los cifran.



Corrupción silenciosa

El malware lleva semanas: las copias 'buenas' ya están comprometidas.



No sé cuál está limpia

Sin verificación de integridad, restaurar puede reinfectar.



Recuperación no probada

El respaldo nunca se restauró de verdad; el RTO/RPO real aparece el día del incidente.

MITRE ATT&CK • las dos técnicas que nos importan

Lenguaje común para describir al adversario (táctica: Impact)

T1486

Data Encrypted for Impact

El adversario cifra datos y sistemas para interrumpir la operación y forzar el pago.

- Cifra archivos, bases de datos y a veces el arranque
- Suele combinarse con exfiltración (doble extorsión)
- Detección: creación masiva de archivos y alta entropía

T1490

Inhibit System Recovery

El adversario elimina o desactiva los mecanismos de recuperación.

- Borra Volume Shadow Copies y snapshots
- Desactiva reparación de arranque y catálogos de backup
- Por eso una bóveda inmutable / WORM cambia el juego

Cómo debe operar el equipo de seguridad

Un proceso por capas alineado a NIST CSF 2.0, con IA como copiloto



El rol de la IA: agiliza DETECT y RESPOND (triage de alertas, correlación, generación de reglas), pero cada decisión la valida el analista. La automatización se usa en pasos acotados y reversibles — nunca decisiones críticas sin humano.

NIST CSF 2.0 • la función RECOVER

Dónde encaja la ciber-recuperación en el marco de gestión de riesgo



RC.RP Incident Recovery Plan Execution

- Ejecutar el plan durante y después del incidente
- Verificar la integridad de los respaldos antes de restaurar
- Restaurar priorizando sistemas críticos

RC.CO Incident Recovery Communication

- Coordinar con partes internas y externas
- Comunicar el progreso a dirección e interesados
- Gestionar proveedores y autoridades

Guía práctica: NIST SP 800-184 — Guide for Cybersecurity Event Recovery.

La regla de respaldo 3-2-1-1-0

La evolución del 3-2-1 clásico para la era del ransomware



El '1' inmutable y el '0' verificado son justo lo que neutraliza a T1490. Los construimos en las sesiones 4 y 5.

Caso 1 • EPM (Medellín, diciembre 2022)

Ransomware BlackCat/ALPHV contra una empresa de servicios públicos

- EPM — energía, agua y gas — sufrió un ataque de BlackCat que afectó buena parte de su infraestructura tecnológica.
- El grupo reivindicó el ataque y comenzó a filtrar información robada (doble extorsión).
- Impacto operativo: atención degradada y planes de contingencia manuales durante días.

Qué nos enseña

- La doble extorsión hace que el backup no baste: hay que asumir la fuga.
- La continuidad manual compra tiempo, a un costo enorme.
- Detectar temprano (T1486/T1490) y tener copias inmutables cambia el desenlace.

Caso 2 • IFX Networks (septiembre 2023)

Un ataque a un proveedor que golpeó a decenas de entidades a la vez

- IFX Networks, proveedor de datacenter/nube, fue atacado (atribuido a RansomHouse), afectando en cascada a cientos de organizaciones de la región.
- En Colombia impactó servicios de la Rama Judicial, salud y entidades del Estado.
- El Gobierno activó la PMU CIBER de MinTIC para coordinar la respuesta nacional.

Qué nos enseña

- El riesgo es de cadena de suministro: dependes de terceros.
- La recuperación es lenta cuando no controlas la infraestructura ni las copias.
- Necesitas tu propia capacidad de verificar integridad y recuperar.

Lleva el modelo a la data, no la data al modelo

El principio forense que define cómo usamos la IA en este curso

✗ Llevar la data al modelo



Subes la evidencia a un modelo público → sale de tu control

- Rompe la cadena de custodia
- Expone PII y datos del caso
- El proveedor puede retener la data

✓ Llevar el modelo a la data



El modelo corre local, sobre tu backup/imagen forense → nada sale

- Preserva la cadena de custodia
- La evidencia nunca abandona tu entorno
- Funciona offline / air-gapped

Por qué local y no un modelo público

Cuando hay evidencia de por medio, el dónde corre el modelo es una decisión forense



Cadena de custodia

Un tercero en el flujo debilita el valor probatorio de la evidencia.



Confidencialidad / PII

Enviar un backup a un API público es, en sí, una fuga de datos.



Retención del proveedor

No controlas qué guarda el servicio, por cuánto tiempo ni para qué.



Control total

Local = offline si hace falta; tú decides qué entra y qué sale.

No es que la IA pública sea 'mala' — es que la evidencia no se expone. Para datos sintéticos del lab, hosted está bien.

Modelo abierto vs. modelo público

No son lo mismo — y la diferencia importa para la evidencia



Modelo abierto (pesos)

- Descargas los pesos y lo ejecutas TÚ
- Corre local o en tu infraestructura
- La data NO sale de tu entorno
- Ej.: Llama, Qwen, Mistral, Foundation-Sec-8B
- Apto para EVIDENCIA (air-gapped)



Modelo público (API)

- Consume un servicio remoto por API
- Corre en los servidores del proveedor
- La data SALE hacia el proveedor
- Ej.: GPT-4o, Claude, Gemini (API)
- Solo datos NO sensibles / sintéticos

«Abierto» = puedes descargar y ejecutar. «Público» = servicio de terceros. Lo que protege la evidencia es DÓNDE corre.

¿Qué modelo según tu hardware?

Elegimos por lo que tu equipo puede correr — sin perder privacidad

8 GB RAM, sin GPU	llama3.2:3b / qwen2.5:3b	Básico, para aprender el flujo
16–24 GB RAM (Mac M-series)	llama3.1:8b ← el del curso	Equilibrio calidad + privacidad
GPU 24 GB+ (workstation)	qwen2.5:32b / 70B cuantizado	Mejor razonamiento, aún local
Servidor multi-GPU	llama3.3:70b / Foundation-Sec-8B-Reasoning	Nivel producción, sigue local

Por qué el curso usa llama3.1:8b: corre local en 16–24 GB, sigue bien las instrucciones del triage y mantiene la privacidad.

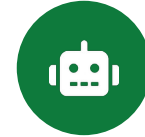
Modelos abiertos en Hugging Face para el caso

De dónde salen los pesos y cuáles sirven para este ejercicio



Foundation-Sec-8B (Cisco)

Especializado en seguridad, sobre Llama-3.1-8B. Variantes: base, Instruct, Reasoning.



Llama 3.1 / 3.2 (Meta)

Generales sólidos; 8B es el punto dulce local para el triage del curso.



Qwen2.5 / Mistral / Gemma

Alternativas abiertas fuertes (3B a 32B) según tu hardware.



Cómo ejecutarlos

Ollama (pull directo) o GGUF + Modelfile / llama.cpp para pesos de HF.

Para el taller: usamos llama3.1:8b vía Ollama por simplicidad; Foundation-Sec-8B queda como reto avanzado (GGUF). Requiere cuenta gratuita de Hugging Face.

El taller en dos tiempos

Primero el investigador; después el copiloto

Parte 1 • Forense a mano

- Descargas el 'backup' del caso (Ubuntu/Warp)
- file: extensión vs. contenido (magic number)
- sha256sum: integridad (¿me cambiaron un archivo?)
- entropía: ¿está cifrado? (~8.0)
- El agente de Warp (OZ) ayuda con los comandos



Parte 2 • Copiloto de IA

- El modelo LOCAL corre sobre tus hallazgos
- Estructura y mapea a MITRE ATT&CK
- Contrastas: ¿la IA coincide contigo? ¿alucinó?
- Tu análisis manual es el control de calidad
- Copiloto, no piloto

Próxima sesión • qué viene y qué alistar

Sesión 2 — Análisis de integridad con herramientas abiertas

En la Sesión 2 veremos

- Entropía de Shannon para detectar cifrado
- Cifrado parcial y magic number vs. extensión
- Hashing difuso (ssdeep / TLSH) para variantes
- Scoring de corrupción y anomalías con scikit-learn
- Del dato a la decisión: ¿esta copia está limpia?

Qué debes traer listo

- El laboratorio de HOY funcionando (setup elegido)
- make check en verde (backend LLM operativo)
- Ubuntu con el entorno del kit ya instalado
- Tu .env configurado (local u hosted)
- Dudas del lab resueltas antes de empezar

¿Preguntas antes del laboratorio?



Recuerda la estrella polar: recuperar con confianza no es tener copias, es poder verificar cuál copia está limpia y restaurarla sin reinfectarse.